



**Payment Card Industry (PCI)
Data Security Standard**

Self-Assessment Questionnaire D and Attestation of Compliance for Merchants

All other SAQ-Eligible Merchants

Version 3.0

February 2014

Section 1: Assessment Information

Instructions for Submission

This document must be completed as a declaration of the results of the merchant's self-assessment with the *Payment Card Industry Data Security Standard Requirements and Security Assessment Procedures (PCI DSS)*. Complete all sections: The merchant is responsible for ensuring that each section is completed by the relevant parties, as applicable. Contact acquirer (merchant bank) or the payment brands to determine reporting and submission procedures.

Part 1. Merchant and Qualified Security Assessor Information

Part 1a. Merchant Organization Information

Company Name:	SnowBe Online	DBA (doing business as):	
Contact Name:		Title:	
ISA Name(s) (if applicable):		Title:	
Telephone:		E-mail:	
Business Address:		City:	
State/Province:		Country:	
URL:		Zip:	

Part 1b. Qualified Security Assessor Company Information (if applicable)

Company Name:			
Lead QSA Contact Name:	Jarred Ward	Title:	
Telephone:		E-mail:	
Business Address:		City:	
State/Province:		Country:	
URL:		Zip:	

Part 2. Executive Summary

Part 2a. Type of Merchant Business (check all that apply)

- | | | |
|---|--|--|
| ☒ Retailer | ☐ Telecommunication | ☐ Grocery and Supermarkets |
| ☐ Petroleum | ☒ E-Commerce | ☐ Mail order/telephone order (MOTO) |
| ☐ Others (please specify): | | |

What types of payment channels does your business serve?

- ☐ Mail order/telephone order (MOTO)
- ☒ E-Commerce
- ☒ Card-present (face-to-face)

Which payment channels are covered by this SAQ?

- ☐ Mail order/telephone order (MOTO)
- ☒ E-Commerce
- ☒ Card-present (face-to-face)

Note: If your organization has a payment channel or process that is not covered by this SAQ, consult your acquirer or payment brand about validation for the other channels.

Part 2b. Description of Payment Card Business

How and in what capacity does your business store, process and/or transmit cardholder data?

Processing/Transmission is achieved via encrypted API connection to payment processing system. SnowBe Online stores CHD on the company website.

Part 2c. Locations

List types of facilities and a summary of locations included in the PCI DSS review (for example, retail outlets, corporate offices, data centers, call centers, etc.)

Type of facility	Location(s) of facility (city, country)
Storefront	United States & Europe
AWS Data Center	United States & Europe
Corporate Office	Los Angeles, United States

Part 2d. Payment Application

Does the organization use one or more Payment Applications? ☒ Yes ☐ No

Provide the following information regarding the Payment Applications your organization uses:

Payment Application Name	Version Number	Application Vendor	Is application PA-DSS Listed?	PA-DSS Listing Expiry date (if applicable)
Credit Card Terminals		Bank Provided	☐ Yes ☐ No	
WordPress Shopping Cart		WordPress	☐ Yes ☐ No	
			☐ Yes ☐ No	

Part 2e. Description of Environment

Provide a **high-level** description of the environment covered by this assessment.

For example:

- *Connections into and out of the cardholder data environment (CDE).*
- *Critical system components within the CDE, such as POS devices, databases, web servers, etc., and any other necessary payment components, as applicable.*

SnowBe Online's cardholder data environment (CDE) includes its AWS-hosted WordPress e-commerce website, associated databases, and internal servers that store, process, and transmit cardholder data. Customers access the system over the Internet, while employees connect through desktops and VPN-enabled laptops.

Does your business use network segmentation to affect the scope of your PCI DSS environment? (Refer to "Network Segmentation" section of PCI DSS for guidance on network segmentation)

☐ Yes

☒ No

Part 2f. Third-Party Service Providers

Does your company share cardholder data with any third-party service providers (for example, gateways, payment processors, payment service providers (PSP), web-hosting companies, airline booking agents, loyalty program agents, etc.)?

☒ Yes

☐ No

If Yes:

Name of service provider:	Description of services provided:
Amazon Web Services (AWS)	Cloud Hosting/ Infrastructure as a Services (IaaS)
Bank Payment Processor	Processes card Transactions via PCI DSS Level 1 Terminals

Note: Requirement 12.8 applies to all entities in this list.

Section 2: Self-Assessment Questionnaire D for Merchants

Note: The following questions are numbered according to PCI DSS requirements and testing procedures, as defined in the PCI DSS Requirements and Security Assessment Procedures document.

Self-assessment completion date:

Build and Maintain a Secure Network and Systems

Requirement 1: Install and maintain a firewall configuration to protect data

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
1.1	Are firewall and router configuration standards established and implemented to include the following:						
1.1.1	Is there a formal process for approving and testing all network connections and changes to the firewall and router configurations?	- Review documented process - Interview personnel - Examine network configurations	☐	☐	☒	☐	☐
1.1.2	(a) Is there a current network diagram that documents all connections between the cardholder data environment and other networks, including any wireless networks?	- Review current network diagram - Examine network configurations	☐	☐	☒	☐	☐
	(b) Is there a process to ensure the diagram is kept current?	Interview responsible personnel	☐	☐	☒	☐	☐
1.1.3	(a) Is there a current diagram that shows all cardholder data flows across systems and networks?	- Review current dataflow diagram - Examine network configurations.	☐	☐	☒	☐	☐
	(b) Is there a process to ensure the diagram is kept current?	Interview personnel	☐	☐	☒	☐	☐
1.1.4	(a) Is a firewall required and implemented at each Internet connection and between any demilitarized zone (DMZ) and the internal network zone?	- Review firewall configuration standards - Observe network configurations to verify that a firewall(s) is in place	☐	☐	☒	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
	(b) Is the current network diagram consistent with the firewall configuration standards?	Compare firewall configuration standards to current network diagram	☐	☐	☒	☐	☐
1.1.5	Are groups, roles, and responsibilities for logical management of network components assigned and documented in the firewall and router configuration standards?	- Review firewall and router configuration standards - Interview personnel	☐	☐	☒	☐	☐
1.1.6	(a) Do firewall and router configuration standards include a documented list of services, protocols, and ports, including business justification (for example, hypertext transfer protocol (HTTP), Secure Sockets Layer (SSL), Secure Shell (SSH), and Virtual Private Network (VPN) protocols)?	Review firewall and router configuration standards	☐	☐	☒	☐	☐
	(b) Are all insecure services, protocols, and ports identified, and are security features documented and implemented for each identified service? Note: Examples of insecure services, protocols, or ports include but are not limited to FTP, Telnet, POP3, IMAP, and SNMP.	- Review firewall and router configuration standards - Examine firewall and router configurations	☐	☐	☒	☐	☐
1.1.7	(a) Do firewall and router configuration standards require review of firewall and router rule sets at least every six months?	Review firewall and router configuration standards	☐	☐	☒	☐	☐
	(b) Are firewall and router rule sets reviewed at least every six months?	Examine documentation from firewall reviews	☐	☐	☒	☐	☐
1.2	Do firewall and router configurations restrict connections between untrusted networks and any system in the cardholder data environment as follows: Note: An “untrusted network” is any network that is external to the networks belonging to the entity under review, and/or which is out of the entity’s ability to control or manage.						

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
1.2.1	(a) Is inbound and outbound traffic restricted to that which is necessary for the cardholder data environment?	- Review firewall and router configuration standards - Examine firewall and router configurations	☐	☐	☒	☐	☐
	(b) Is all other inbound and outbound traffic specifically denied (for example by using an explicit “deny all” or an implicit deny after allow statement)?	- Review firewall and router configuration standards - Examine firewall and router configurations	☐	☐	☒	☐	☐
1.2.2	Are router configuration files secured from unauthorized access and synchronized—for example, the running (or active) configuration matches the start-up configuration (used when machines are booted)?	- Review firewall and router configuration standards - Examine router configuration files and router configurations	☐	☐	☒	☐	☐
1.2.3	Are perimeter firewalls installed between all wireless networks and the cardholder data environment, and are these firewalls configured to deny or, if traffic is necessary for business purposes, permit only authorized traffic between the wireless environment and the cardholder data environment?	- Review firewall and router configuration standards - Examine firewall and router configurations	☐	☐	☒	☐	☐
1.3	Is direct public access prohibited between the Internet and any system component in the cardholder data environment, as follows:						
1.3.1	Is a DMZ implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports?	Examine firewall and router configurations	☐	☐	☒	☐	☐
1.3.2	Is inbound Internet traffic limited to IP addresses within the DMZ?	Examine firewall and router configurations	☐	☐	☒	☐	☐
1.3.3	Are direct connections prohibited for inbound or outbound traffic between the Internet and the cardholder data environment?	Examine firewall and router configurations	☐	☐	☒	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
1.3.4	Are anti-spoofing measures implemented to detect and block forged sourced IP addresses from entering the network? (For example, block traffic originating from the internet with an internal address.)	▪ Examine firewall and router configurations	☐	☐	☒	☐	☐
1.3.5	Is outbound traffic from the cardholder data environment to the Internet explicitly authorized?	▪ Examine firewall and router configurations	☐	☐	☒	☐	☐
1.3.6	Is stateful inspection, also known as dynamic packet filtering, implemented—that is, only established connections are allowed into the network?	▪ Examine firewall and router configurations	☐	☐	☒	☐	☐
1.3.7	Are system components that store cardholder data (such as a database) placed in an internal network zone, segregated from the DMZ and other untrusted networks?	▪ Examine firewall and router configurations	☐	☐	☒	☐	☐
1.3.8	(a) Are methods in place to prevent the disclosure of private IP addresses and routing information to the Internet? Note: <i>Methods to obscure IP addressing may include, but are not limited to:</i> • Network Address Translation (NAT) • Placing servers containing cardholder data behind proxy servers/firewalls, • Removal or filtering of route advertisements for private networks that employ registered addressing, • Internal use of RFC1918 address space instead of registered addresses.	▪ Examine firewall and router configurations	☐	☐	☒	☐	☐
	(b) Is any disclosure of private IP addresses and routing information to external entities authorized?	▪ Examine firewall and router configurations ▪ Interview personnel	☐	☐	☒	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
1.4	(a) Is personal firewall software installed and active on any mobile and/or employee-owned devices that connect to the Internet when outside the network (for example, laptops used by employees), and which are also used to access the network?	- Review policies and configuration standards - Examine mobile and/or employee-owned devices	☐	☐	☒	☐	☐
	(b) Is the personal firewall software configured to specific configuration settings, actively running, and not alterable by users of mobile and/or employee-owned devices?	- Review policies and configuration standards - Examine mobile and/or employee-owned devices	☐	☐	☒	☐	☐
1.5	Are security policies and operational procedures for managing firewalls: - Documented - In use - Known to all affected parties?	- Review security policies and operational procedures - Interview personnel	☐	☐	☒	☐	☐

Requirement 2: Do not use vendor-supplied defaults for system passwords and other security parameters

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
2.1	(a) Are vendor-supplied defaults always changed before installing a system on the network? <i>This applies to ALL default passwords, including but not limited to those used by operating systems, software that provides security services, application and system accounts, point-of-sale (POS) terminals, Simple Network Management Protocol (SNMP) community strings, etc.).</i>	- Review policies and procedures - Examine vendor documentation - Observe system configurations and account settings - Interview personnel	☒	☐	☐	☐	☐
	(b) Are unnecessary default accounts removed or disabled before installing a system on the network?	- Review policies and procedures - Review vendor documentation - Examine system configurations and account settings - Interview personnel	☐	☐	☒	☐	☐
2.1.1	For wireless environments connected to the cardholder data environment or transmitting cardholder data, are ALL wireless vendor defaults changed at installations, as follows:						
	(a) Are encryption keys changed from default at installation, and changed anytime anyone with knowledge of the keys leaves the company or changes positions?	- Review policies and procedures - Review vendor documentation - Interview personnel	☐	☐	☒	☐	☐
	(b) Are default SNMP community strings on wireless devices changed at installation?	- Review policies and procedures - Review vendor documentation - Interview personnel - Examine system configurations	☐	☐	☒	☐	☐
	(c) Are default passwords/passphrases on access points changed at installation?	- Review policies and procedures - Interview personnel - Examine system configurations	☒	☐	☐	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
	(d) Is firmware on wireless devices updated to support strong encryption for authentication and transmission over wireless networks?	- Review policies and procedures - Review vendor documentation - Examine system configurations	☒	☐	☐	☐	☐
	(e) Are other security-related wireless vendor defaults changed, if applicable?	- Review policies and procedures - Review vendor documentation - Examine system configurations	☒	☐	☐	☐	☐
2.2	(a) Are configuration standards developed for all system components and are they consistent with industry-accepted system hardening standards? <i>Sources of industry-accepted system hardening standards may include, but are not limited to, SysAdmin Audit Network Security (SANS) Institute, National Institute of Standards Technology (NIST), International Organization for Standardization (ISO), and Center for Internet Security (CIS).</i>	- Review system configuration standards - Review industry-accepted hardening standards - Review policies and procedures - Interview personnel	☒	☐	☐	☐	☐
	(b) Are system configuration standards updated as new vulnerability issues are identified, as defined in Requirement 6.1?	- Review policies and procedures - Interview personnel	☐	☐	☒	☐	☐
	(c) Are system configuration standards applied when new systems are configured?	- Review policies and procedures - Interview personnel	☐	☐	☒	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
	(d) Do system configuration standards include all of the following: • Changing of all vendor-supplied defaults and elimination of unnecessary default accounts? • Implementing only one primary function per server to prevent functions that require different security levels from co-existing on the same server? • Enabling only necessary services, protocols, daemons, etc., as required for the function of the system? • Implementing additional security features for any required services, protocols or daemons that are considered to be insecure? • Configuring system security parameters to prevent misuse? • Removing all unnecessary functionality, such as scripts, drivers, features, subsystems, file systems, and unnecessary web servers?	▪ Review system configuration standards	☐	☐	☒	☐	☐
2.2.1	(a) Is only one primary function implemented per server, to prevent functions that require different security levels from co-existing on the same server? <i>For example, web servers, database servers, and DNS should be implemented on separate servers.</i>	▪ Examine system configurations	☒	☐	☐	☐	☐
	(b) If virtualization technologies are used, is only one primary function implemented per virtual system component or device?	▪ Examine system configurations	☐	☐	☐	☒	☐
2.2.2	(a) Are only necessary services, protocols, daemons, etc. enabled as required for the function of the system (services and protocols not directly needed to perform the device's specified function are disabled)?	▪ Review configuration standards ▪ Examine system configurations	☐	☐	☒	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
	(b) Are all enabled insecure services, daemons, or protocols justified per documented configuration standards?	- Review configuration standards - Interview personnel - Examine configuration settings - Compare enabled services, etc. to documented justifications	☐	☐	☒	☐	☐
2.2.3	Are additional security features documented and implemented for any required services, protocols or daemons that are considered to be insecure? <i>For example, use secured technologies such as SSH, S-FTP, SSL or IPSec VPN to protect insecure services such as NetBIOS, file-sharing, Telnet, FTP, etc.</i>	- Review configuration standards - Examine configuration settings	☐	☐	☒	☐	☐
2.2.4	(a) Are system administrators and/or personnel that configure system components knowledgeable about common security parameter settings for those system components?	Interview personnel	☐	☐	☐	☐	☒
	(b) Are common system security parameters settings included in the system configuration standards?	Review system configuration standards	☐	☐	☒	☐	☐
	(c) Are security parameter settings set appropriately on system components?	- Examine system components - Examine security parameter settings - Compare settings to system configuration standards	☐	☐	☒	☐	☐
2.2.5	(a) Has all unnecessary functionality—such as scripts, drivers, features, subsystems, file systems, and unnecessary web servers—been removed?	Examine security parameters on system components	☐	☐	☒	☐	☐
	(b) Are enabled functions documented and do they support secure configuration?	- Review documentation - Examine security parameters on system components	☐	☐	☒	☐	☐
	(c) Is only documented functionality present on system components?	- Review documentation - Examine security parameters on system components	☐	☐	☒	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
2.3	Is non-console administrative access encrypted as follows: <i>Use technologies such as SSH, VPN, or SSL/TLS for web-based management and other non-console administrative access.</i>						
	(a) Is all non-console administrative access encrypted with strong cryptography, and is a strong encryption method invoked before the administrator's password is requested?	- Examine system components - Examine system configurations - Observe an administrator log on	☐	☐	☒	☐	☐
	(b) Are system services and parameter files configured to prevent the use of Telnet and other insecure remote login commands?	- Examine system components - Examine services and files	☐	☐	☒	☐	☐
	(c) Is administrator access to web-based management interfaces encrypted with strong cryptography?	- Examine system components - Observe an administrator log on	☐	☐	☒	☐	☐
	(d) For the technology in use, is strong cryptography implemented according to industry best practice and/or vendor recommendations?	- Examine system components - Review vendor documentation - Interview personnel	☐	☐	☒	☐	☐
2.4	(a) Is an inventory maintained for systems components that are in scope for PCI DSS, including a list of hardware and software components and a description of function/use for each?	Examine system inventory	☐	☐	☒	☐	☐
	(b) Is the documented inventory kept current?	Interview personnel	☐	☐	☒	☐	☐
2.5	Are security policies and operational procedures for managing vendor defaults and other security parameters: - Documented - In use - Known to all affected parties?	- Review security policies and operational procedures - Interview personnel	☐	☐	☒	☐	☐
2.6	<i>This requirement applies only to service providers.</i>						

Protect Cardholder Data

Requirement 3: Protect stored cardholder data

PCI DSS Question	Expected Testing	Response (Check one response for each question)				
		Yes	Yes with CCW	No	N/A	Not Tested
3.1	Are data-retention and disposal policies, procedures, and processes implemented as follows:					
(a)	Is data storage amount and retention time limited to that required for legal, regulatory, and business requirements? - Review data retention and disposal policies and procedures - Interview personnel	☐	☐	☒	☐	☐
(b)	Are there defined processes in place for securely deleting cardholder data when no longer needed for legal, regulatory, or business reasons? - Review policies and procedures - Interview personnel - Examine deletion mechanism	☐	☐	☒	☐	☐
(c)	Are there specific retention requirements for cardholder data? <i>For example, cardholder data needs to be held for X period for Y business reasons.</i> - Review policies and procedures - Interview personnel - Examine retention requirements	☐	☐	☒	☐	☐
(d)	Is there a quarterly process for identifying and securely deleting stored cardholder data that exceeds defined retention requirements? - Review policies and procedures - Interview personnel - Observe deletion processes	☐	☐	☒	☐	☐
(e)	Does all stored cardholder data meet the requirements defined in the data-retention policy? Examine files and system records	☐	☐	☒	☐	☐
3.2	(a) <i>This testing procedure applies only to Issuers.</i>					
	(b) <i>This testing procedure applies only to Issuers.</i>					
	(c) Is sensitive authentication data deleted or rendered unrecoverable upon completion of the authorization process? - Review policies and procedures - Examine system configurations - Examine deletion processes	☐	☐	☒	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
	(d) Do all systems adhere to the following requirements regarding non-storage of sensitive authentication data after authorization (even if encrypted):						
3.2.1	The full contents of any track (from the magnetic stripe located on the back of a card, equivalent data contained on a chip, or elsewhere) are not stored after authorization? <i>This data is alternatively called full track, track, track 1, track 2, and magnetic-stripe data.</i> Note: In the normal course of business, the following data elements from the magnetic stripe may need to be retained: • The cardholder's name, • Primary account number (PAN), • Expiration date, and • Service code <i>To minimize risk, store only these data elements as needed for business.</i>	▪ Examine data sources including: • Incoming transaction data • All logs • History files • Trace files • Database schema • Database contents	☐	☐	☐	☐	☐
3.2.2	The card verification code or value (three-digit or four-digit number printed on the front or back of a payment card) is not stored after authorization?	▪ Examine data sources including: • Incoming transaction data • All logs • History files • Trace files • Database schema • Database contents	☐	☐	☐	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
3.2.3	The personal identification number (PIN) or the encrypted PIN block is not stored after authorization?	- Examine data sources including: - Incoming transaction data - All logs - History files - Trace files - Database schema - Database contents	☐	☐	☐	☐	☐
3.3	Is the PAN masked when displayed (the first six and last four digits are the maximum number of digits to be displayed) such that only personnel with a legitimate business need can see the full PAN? Note: This requirement does not supersede stricter requirements in place for displays of cardholder data—for example, legal or payment card brand requirements for point-of-sale (POS) receipts.	- Review policies and procedures - Review roles that need access to displays of full PAN - Examine system configurations - Observe displays of PAN	☐	☐	☐	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
3.6.8	Are cryptographic key custodians required to formally acknowledge (in writing or electronically) that they understand and accept their key-custodian responsibilities?	- Review procedures - Review documentation or other evidence	☐	☐	☐	☐	☐
3.7	Are security policies and operational procedures for protecting stored cardholder data: - Documented - In use - Known to all affected parties?	- Review security policies and operational procedures - Interview personnel	☐	☐	☒	☐	☐

Maintain a Vulnerability Management Program

Requirement 5: Protect all systems against malware and regularly update anti-virus software or programs

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
5.1	Is anti-virus software deployed on all systems commonly affected by malicious software?	Examine system configurations	☒	☐	☐	☐	☐
5.1.1	Are anti-virus programs capable of detecting, removing, and protecting against all known types of malicious software (for example, viruses, Trojans, worms, spyware, adware, and rootkits)?	- Review vendor documentation - Examine system configurations	☒	☐	☐	☐	☐
5.1.2	Are periodic evaluations performed to identify and evaluate evolving malware threats in order to confirm whether those systems considered to not be commonly affected by malicious software continue as such?	Interview personnel	☐	☐	☐	☐	☒
5.2	Are all anti-virus mechanisms maintained as follows:						
	(a) Are all anti-virus software and definitions kept current?	- Examine policies and procedures - Examine anti-virus configurations, including the master installation - Examine system components	☒	☐	☐	☐	☐
	(b) Are automatic updates and periodic scans enabled and being performed?	- Examine anti-virus configurations, including the master installation - Examine system components	☐	☐	☐	☐	☒
	(c) Are all anti-virus mechanisms generating audit logs, and are logs retained in accordance with PCI DSS Requirement 10.7?	- Examine anti-virus configurations - Review log retention processes	☐	☐	☐	☐	☒

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
5.3	Are all anti-virus mechanisms: - Actively running? - Unable to be disabled or altered by users? <i>Note: Anti-virus solutions may be temporarily disabled only if there is legitimate technical need, as authorized by management on a case-by-case basis. If anti-virus protection needs to be disabled for a specific purpose, it must be formally authorized. Additional security measures may also need to be implemented for the period of time during which anti-virus protection is not active.</i>	- Examine anti-virus configurations - Examine system components - Observe processes - Interview personnel	☐	☐	☐	☐	☒
5.4	Are security policies and operational procedures for protecting systems against malware: - Documented - In use - Known to all affected parties?	- Review security policies and operational procedures - Interview personnel	☐	☐	☒	☐	☐

Requirement 6: Develop and maintain secure systems and applications

PCI DSS Question	Expected Testing	Response (Check one response for each question)				
		Yes	Yes with CCW	No	N/A	Not Tested
6.1 Is there a process to identify security vulnerabilities, including the following: - Using reputable outside sources for vulnerability information? - Assigning a risk ranking to vulnerabilities that includes identification of all “high” risk and “critical” vulnerabilities? Note: Risk rankings should be based on industry best practices as well as consideration of potential impact. For example, criteria for ranking vulnerabilities may include consideration of the CVSS base score and/or the classification by the vendor, and/or type of systems affected. Methods for evaluating vulnerabilities and assigning risk ratings will vary based on an organization’s environment and risk assessment strategy. Risk rankings should, at a minimum, identify all vulnerabilities considered to be a “high risk” to the environment. In addition to the risk ranking, vulnerabilities may be considered “critical” if they pose an imminent threat to the environment, impact critical systems, and/or would result in a potential compromise if not addressed. Examples of critical systems may include security systems, public-facing devices and systems, databases, and other systems that store, process or transmit cardholder data.	- Review policies and procedures - Interview personnel - Observe processes	☐	☐	☒	☐	☐
6.2 (a) Are all system components and software protected from known vulnerabilities by installing applicable vendor-supplied security patches?	Review policies and procedures	☒	☐	☐	☐	☐
(b) Are critical security patches installed within one month of release? Note: Critical security patches should be identified according to the risk ranking process defined in Requirement 6.1.	- Review policies and procedures - Examine system components - Compare list of security patches installed to recent vendor patch lists	☐	☐	☐	☐	☒

PCI DSS Question	Expected Testing	Response (Check one response for each question)				
		Yes	Yes with CCW	No	N/A	Not Tested
6.3.2 Is all custom code reviewed prior to release to production or customers to identify any potential coding vulnerability (using either manual or automated processes as follows): - Are code changes reviewed by individuals other than the originating code author, and by individuals who are knowledgeable about code review techniques and secure coding practices? - Do code reviews ensure code is developed according to secure coding guidelines? - Are appropriate corrections are implemented prior to release? - Are code review results are reviewed and approved by management prior to release? <i>Note: This requirement for code reviews applies to all custom code (both internal and public-facing), as part of the system development life cycle. Code reviews can be conducted by knowledgeable internal personnel or third parties. Public-facing web applications are also subject to additional controls, to address ongoing threats and vulnerabilities after implementation, as defined at PCI DSS Requirement 6.6.</i>	- Review policies and procedures - Interview personnel - Examine recent changes and change records	☐	☐	☐	☐	☐
6.4	Are change control processes and procedures followed for all changes to system components to include the following:					
6.4.1	(a) Are development/test environments separate from the production environment? - Review change control processes and procedures - Examine network documentation and network device configurations	☐	☐	☒	☐	☐
	(b) Is access control in place to enforce the separation between the development/test environments and the production environment? - Review change control processes and procedures - Examine access control settings	☐	☐	☒	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
6.4.2	Is there separation of duties between personnel assigned to the development/test environments and those assigned to the production environment?	- Review change control processes and procedures - Observe processes - Interview personnel	☐	☐	☒	☐	☐
6.4.3	Are production data (live PANs) not used for testing or development?	- Review change control processes and procedures - Observe processes - Interview personnel - Examine test data	☐	☐	☒	☐	☐
6.4.4	Are test data and accounts removed before production systems become active?	- Review change control processes and procedures - Observe processes - Interview personnel - Examine production systems	☐	☐	☒	☐	☐
6.4.5	(a) Are change-control procedures for implementing security patches and software modifications documented and require the following? - Documentation of impact - Documented change control approval by authorized parties - Functionality testing to verify that the change does not adversely impact the security of the system - Back-out procedures	Review change control processes and procedures	☐	☐	☒	☐	☐
	(b) Are the following performed and documented for all changes:						
6.4.5.1	Documentation of impact?	- Trace changes to change control documentation - Examine change control documentation	☐	☐	☐	☐	☒

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
6.4.5.2	Documented approval by authorized parties?	- Trace changes to change control documentation - Examine change control documentation	☐	☐	☒	☐	☐
6.4.5.3	(a) Functionality testing to verify that the change does not adversely impact the security of the system?	- Trace changes to change control documentation - Examine change control documentation	☐	☐	☒	☐	☐
	(b) For custom code changes, testing of updates for compliance with PCI DSS Requirement 6.5 before being deployed into production?	- Trace changes to change control documentation - Examine change control documentation	☐	☐	☒	☐	☐
6.4.5.4	Back-out procedures?	- Trace changes to change control documentation - Examine change control documentation	☐	☐	☒	☐	☐
6.5	(a) Do software-development processes address common coding vulnerabilities?	Review software-development policies and procedures	☐	☐	☐	☐	☐
	(b) Are developers trained in secure coding techniques, including how to avoid common coding vulnerabilities, and understanding how sensitive data is handled in memory?	- Interview personnel - Examine training records					
	(c) Are applications developed based on secure coding guidelines to protect applications from, at a minimum, the following vulnerabilities: Note: The vulnerabilities listed at 6.5.1 through 6.5.10 were current with industry best practices when this version of PCI DSS was published. However, as industry best practices for vulnerability management are updated (for example, the Open Web Application Security Project (OWASP) Guide, SANS CWE Top 25, CERT Secure Coding, etc.), the current best practices must be used for these requirements.						

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
6.5.9	Do coding techniques address cross-site request forgery (CSRF)?	- Examine software-development policies and procedures - Interview responsible personnel	☐	☐	☐	☐	☐
6.5.10	Do coding techniques address broken authentication and session management? <i>Note: Requirement 6.5.10 is a best practice until June 30, 2015, after which it becomes a requirement.</i>	- Examine software-development policies and procedures - Interview responsible personnel	☐	☐	☐	☐	☐
6.6	For public-facing web applications, are new threats and vulnerabilities addressed on an ongoing basis, and are these applications protected against known attacks by applying <i>either</i> of the following methods? - Reviewing public-facing web applications via manual or automated application vulnerability security assessment tools or methods, as follows: - At least annually - After any changes - By an organization that specializes in application security - That all vulnerabilities are corrected - That the application is re-evaluated after the corrections <i>Note: This assessment is not the same as the vulnerability scans performed for Requirement 11.2.</i> – OR – - Installing an automated technical solution that detects and prevents web-based attacks (for example, a web-application firewall) in front of public-facing web applications to continually check all traffic.	- Review documented processes - Interview personnel - Examine records of application security assessments - Examine system configuration settings	☐	☐	☐	☐	☒

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
6.7	Are security policies and operational procedures for developing and maintaining secure systems and applications: ▪ Documented ▪ In use ▪ Known to all affected parties?	▪ Review security policies and operational procedures ▪ Interview personnel	☐	☐	☒	☐	☐

Implement Strong Access Control Measures

Requirement 7: Restrict access to cardholder data by business need to know

PCI DSS Question	Expected Testing	Response (Check one response for each question)				
		Yes	Yes with CCW	No	N/A	Not Tested
7.1	Is access to system components and cardholder data limited to only those individuals whose jobs require such access, as follows:					
	- Is there a written policy for access control that incorporates the following? - Defining access needs and privilege assignments for each role - Restriction of access to privileged user IDs to least privileges necessary to perform job responsibilities, - Assignment of access based on individual personnel's job classification and function - Documented approval (electronically or in writing) by authorized parties for all access, including listing of specific privileges approved	☐	☐	☒	☐	☐
7.1.1	Are access needs for each role defined, including: - System components and data resources that each role needs to access for their job function? - Level of privilege required (for example, user, administrator, etc.) for accessing resources?	☒	☐	☐	☐	☐
7.1.2	Is access to privileged user IDs restricted as follows: - To least privileges necessary to perform job responsibilities? - Assigned only to roles that specifically require that privileged access?	☒	☐	☐	☐	☐
7.1.3	Are access assigned based on individual personnel's job classification and function? - Interview management - Review user IDs	☒	☐	☐	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
7.1.4	Is documented approval by authorized parties required, specifying required privileges?	- Review user IDs - Compare with documented approvals - Compare assigned privileges with documented approvals	☐	☐	☒	☐	☐
7.2	Is an access control system in place for system components to restrict access based on a user's need to know, and is it set to "deny all" unless specifically allowed, as follows:						
7.2.1	Are access control systems in place on all system components?	- Review vendor documentation - Examine configuration settings	☒	☐	☐	☐	☐
7.2.2	Are access control systems configured to enforce privileges assigned to individuals based on job classification and function?	- Review vendor documentation - Examine configuration settings	☒	☐	☐	☐	☐
7.2.3	Do access control systems have a default "deny-all" setting?	- Review vendor documentation - Examine configuration settings	☐	☐	☒	☐	☐
7.3	Are security policies and operational procedures for restricting access to cardholder data: - Documented - In use - Known to all affected parties?	- Examine security policies and operational procedures - Interview personnel	☐	☐	☒	☐	☐

Requirement 8: Identify and authenticate access to system components

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
8.1	Are policies and procedures for user identification management controls defined and in place for non-consumer users and administrators on all system components, as follows:						
8.1.1	Are all users assigned a unique ID before allowing them to access system components or cardholder data?	- Review password procedures - Interview personnel	☒	☐	☐	☐	☐
8.1.2	Are additions, deletions, and modifications of user IDs, credentials, and other identifier objects controlled such that user IDs are implemented only as authorized (including with specified privileges)?	- Review password procedures - Examine privileged and general user IDs and associated authorizations - Observe system settings	☐	☐	☒	☐	☐
8.1.3	Is access for any terminated users immediately deactivated or removed?	- Review password procedures - Examine terminated users accounts - Review current access lists - Observe returned physical authentication devices	☐	☐	☒	☐	☐
8.1.4	Are inactive user accounts over 90 days old either removed or disabled?	- Review password procedures - Observe user accounts	☐	☐	☒	☐	☐
8.1.5	(a) Are accounts used by vendors to access, support, or maintain system components via remote access enabled only during the time period needed and disabled when not in use?	- Review password procedures - Interview personnel - Observe processes	☐	☐	☒	☐	☐
	(b) Are vendor remote access accounts monitored when in use?	- Interview personnel - Observe processes	☐	☐	☒	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
8.1.6	(a) Are repeated access attempts limited by locking out the user ID after no more than six attempts?	- Review password procedures - Examine system configuration settings	☐	☐	☐	☐	☒
	(b) <i>This testing procedure applies only to service providers.</i>						
8.1.7	Once a user account is locked out, is the lockout duration set to a minimum of 30 minutes or until an administrator enables the user ID?	- Review password procedures - Examine system configuration settings	☐	☐	☐	☐	☒
8.1.8	If a session has been idle for more than 15 minutes, are users required to re-authenticate (for example, re-enter the password) to re-activate the terminal or session?	- Review password procedures - Examine system configuration settings	☐	☐	☐	☐	☒
8.2	In addition to assigning a unique ID, is one or more of the following methods employed to authenticate all users? - Something you know, such as a password or passphrase - Something you have, such as a token device or smart card - Something you are, such as a biometric	- Review password procedures - Observe authentication processes	☒	☐	☐	☐	☐
8.2.1	(a) Is strong cryptography used to render all authentication credentials (such as passwords/phrases) unreadable during transmission and storage on all system components?	- Review password procedures - Review vendor documentation - Examine system configuration settings - Observe password files - Observe data transmissions	☐	☐	☐	☐	☒
	(b) <i>This testing procedure applies only to service providers.</i>						

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
8.2.2	Is user identity verified before modifying any authentication credential (for example, performing password resets, provisioning new tokens, or generating new keys)?	- Review authentication procedures - Observe personnel	☐	☐	☒	☐	☐
8.2.3	(a) Are user password parameters configured to require passwords/passphrases meet the following? - A minimum password length of at least seven characters - Contain both numeric and alphabetic characters Alternatively, the passwords/phrases must have complexity and strength at least equivalent to the parameters specified above.	Examine system configuration settings to verify password parameters	☐	☐	☒	☐	☐
	(b) <i>This testing procedure applies only to service providers.</i>						
8.2.4	(a) Are user passwords/passphrases changed at least every 90 days?	- Review password procedures - Examine system configuration settings	☐	☐	☒	☐	☐
	(b) <i>This testing procedure applies only to service providers.</i>						
8.2.5	(a) Must an individual submit a new password/phrase that is different from any of the last four passwords/phrases he or she has used?	- Review password procedures - Sample system components - Examine system configuration settings	☐	☐	☒	☐	☐
	(b) <i>This testing procedure applies only to service providers.</i>						
8.2.6	Are passwords/phrases set to a unique value for each user for first-time use and upon reset, and must each user change their password immediately after the first use?	- Review password procedures - Examine system configuration settings - Observe security personnel	☐	☐	☒	☐	☐

PCI DSS Question	Expected Testing	Response (Check one response for each question)				
		Yes	Yes with CCW	No	N/A	Not Tested
8.3 Is two-factor authentication incorporated for remote network access originating from outside the network by personnel (including users and administrators) and all third parties (including vendor access for support or maintenance)? <i>Note: Two-factor authentication requires that two of the three authentication methods (see PCI DSS Requirement 8.2 for descriptions of authentication methods) be used for authentication. Using one factor twice (for example, using two separate passwords) is not considered two-factor authentication.</i> <i>Examples of two-factor technologies include remote authentication and dial-in service (RADIUS) with tokens; terminal access controller access control system (TACACS) with tokens; and other technologies that facilitate two-factor authentication.</i>	- Review policies and procedures - Examine system configurations - Observe personnel	☐	☐	☒	☐	☐
8.4 (a) Are authentication procedures and policies documented and communicated to all users?	- Review policies and procedures - Review distribution method - Interview personnel - Interview users	☐	☐	☒	☐	☐
(b) Do authentication procedures and policies include the following? - Guidance on selecting strong authentication credentials - Guidance for how users should protect their authentication credentials - Instructions not to reuse previously used passwords - Instructions that users should change passwords if there is any suspicion the password could be compromised	- Review policies and procedures - Review documentation provided to users	☐	☐	☒	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
8.5	Are group, shared, or generic accounts, passwords, or other authentication methods prohibited as follows: - Generic user IDs and accounts are disabled or removed; - Shared user IDs for system administration activities and other critical functions do not exist; and - Shared and generic user IDs are not used to administer any system components?	- Review policies and procedures - Examine user ID lists - Interview personnel	☐	☐	☒	☐	☐
8.5.1	<i>This requirement applies only to service providers.</i>						
8.6	Where other authentication mechanisms are used (for example, physical or logical security tokens, smart cards, and certificates, etc.), is the use of these mechanisms assigned as follows? - Authentication mechanisms must be assigned to an individual account and not shared among multiple accounts - Physical and/or logical controls must be in place to ensure only the intended account can use that mechanism to gain access	- Review policies and procedures - Interview personnel - Examine system configuration settings and/or physical controls	☐	☐	☒	☐	☐
8.7	Is all access to any database containing cardholder data (including access by applications, administrators, and all other users) restricted as follows:						
	(a) Is all user access to, user queries of, and user actions on (for example, move, copy, delete), the database through programmatic methods only (for example, through stored procedures)?	- Review database authentication policies and procedures - Examine database and application configuration settings	☐	☐	☒	☐	☐

PCI DSS Question		Expected Testing	Response (Check one response for each question)				
			Yes	Yes with CCW	No	N/A	Not Tested
	(b) Is user direct access to or queries to of databases restricted to database administrators?	- Review database authentication policies and procedures - Examine database access control settings - Examine database application configuration settings	☐	☐	☒	☐	☐
	(c) Are application IDs only able to be used by the applications (and not by individual users or other processes)?	- Review database authentication policies and procedures - Examine database access control settings - Examine database application configuration settings	☐	☐	☒	☐	☐
8.8	Are security policies and operational procedures for identification and authentication: - Documented - In use - Known to all affected parties?	- Examine security policies and operational procedures - Interview personnel	☐	☐	☒	☐	☐